

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

PCPJack Hijacks Vulnerable Servers With Worm-Like Cloud Propagation Tactics

Date of Publication

May 13, 2026

Admiralty Code

A1

TA Number

TA2026128

Summary

First Seen: April 28, 2026

Targeted Regions: Global

Targeted Platforms: Linux, Docker, Kubernetes, AWS, Azure, GCP, Cloudflare, Fastly

Targeted Products: Docker, Kubernetes, Redis, MongoDB, RayML, Next.js, React, WordPress (WPVivid Backup, W3 Total Cache), CentOS Web Panel (CWP)

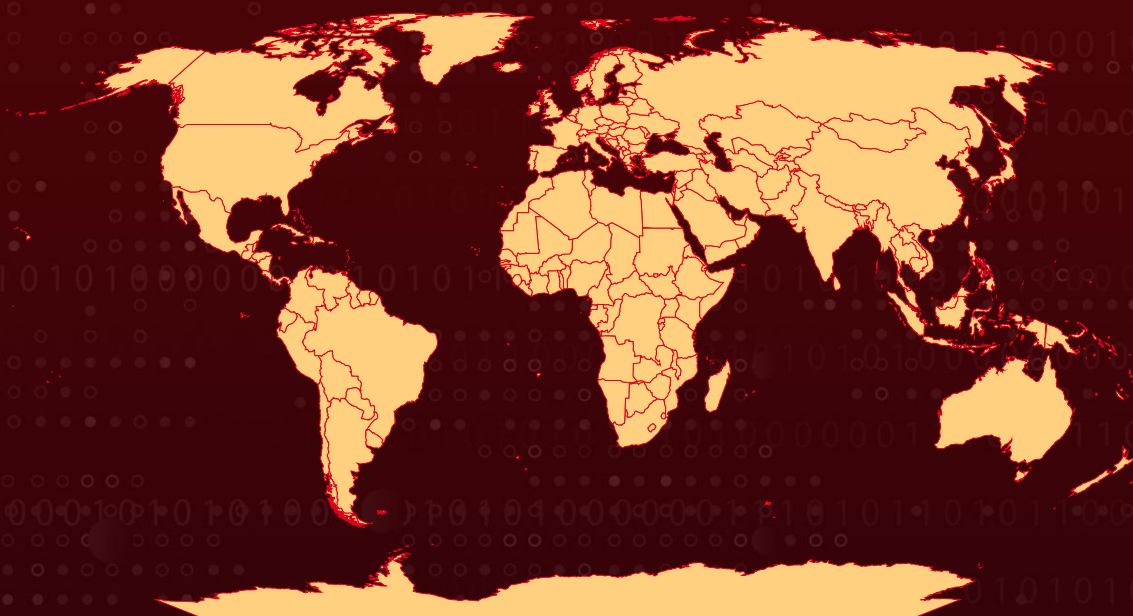
Targeted Industries: Cloud Services, Financial Services, Cryptocurrency, Enterprise Software, Web Hosting

Malware: PCPJack

Attack: PCPJack is a modular credential theft framework that worms across exposed cloud infrastructure, harvesting credentials from cloud, container, developer, productivity, and financial services. The toolset actively evicts and replaces artifacts associated with the TeamPCP threat actor before establishing its own persistence and exfiltrating stolen data through attacker-controlled Telegram channels. Unlike typical cloud-focused malware, PCPJack does not deploy cryptominers, suggesting monetization through credential theft, fraud, spam, extortion, or resale of stolen access.



Attack Regions



Powered by Bing

© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, Open Places, OpenStreetMap, Overture Maps Fundation, TomTom, Zenrin

Targeted

Non-Targeted



THREAT ADVISORY • ATTACK REPORT (Red)

2

Hive Pro

CVE	NAME	AFFECTED PRODUCT	ZERO-DAY	CISA KEV	PATCH
CVE-2025-29927	Next.js Middleware Bypass Vulnerability	Next.js React framework	✗	✗	✓
CVE-2025-55182	React2Shell (Meta React Server Components Remote Code Execution Vulnerability)	Meta React Server Components	✗	✓	✓
CVE-2026-1357	WordPress WPVivid Backup & Migration Unauthenticated Arbitrary File Upload Vulnerability	WordPress WPVivid Backup & Migration	✗	✗	✓
CVE-2025-9501	WordPress W3 Total Cache Command Injection Vulnerability	WordPress W3 Total Cache	✗	✗	✓
CVE-2025-48703	CWP Control Web Panel OS Command Injection Vulnerability	CentOS Web Panel (CWP)	✓	✓	✓

Attack Details

#1

A new malware framework called PCPJack is stealing credentials from exposed cloud infrastructure while actively removing TeamPCP's access to the systems. The infection chain begins with the execution of a shell script named `bootstrap.sh`, which acts as the initial dropper on compromised Linux machines. The script prepares a hidden working directory at `/var/lib/.spm/` and checks the victim's public IP address against an operator-maintained blocklist to avoid self-infection. Before deploying its payloads, PCPJack systematically removes processes, services, containers, and file paths linked to TeamPCP and earlier PCPcat campaigns, suggesting an effort to take exclusive control of already compromised environments. It then installs Python 3.6 or later, creates a virtual environment, and downloads several Python modules from an attacker-controlled Amazon S3 bucket hosted on a typosquatted domain. These modules provide orchestration, credential harvesting, lateral movement, encryption, cloud IP tracking, and internet-scale scanning capabilities.

#2

Once deployed, the framework launches `monitor.py`, which aggressively searches the infected system for sensitive data and exposed secrets. PCPJack harvests `.env` files, configuration files, SSH keys, Docker secrets, Kubernetes service account tokens, AWS IMDS credentials, and cryptocurrency wallet information. It also scans Git history and environment variables for deleted or exposed secrets that may still be recoverable. Using regex-based parsing, the malware identifies credentials associated with more than 30 services, including Binance, Coinbase, Stripe, AWS, GitHub, Slack, Gmail, Twilio, WordPress, and SSH infrastructure. To hinder analysis, strings embedded within the malware are obfuscated through hex encoding and XOR decryption using an MD5-derived key based on the string `urllib3.poolmanager`. Stolen data is encrypted with X25519 and ChaCha20-Poly1305 before being exfiltrated through Telegram channels, although the malware silently falls back to plaintext transmission if the required cryptographic library is unavailable.

#3

PCPJack also includes extensive lateral movement and propagation capabilities designed for cloud-native and enterprise environments. Its Kubernetes module abuses service account tokens to enumerate namespaces and pods, extract secrets, harvest SSH keys, and query AWS metadata services, while also attempting container escapes by mounting the host filesystem. The Docker module scans for exposed Docker sockets and APIs on ports 2375 and 2376, allowing the malware to enumerate running containers and spread internally. Additional modules target Redis, RayML clusters on port 8265, and MongoDB instances on port 27017 for credential theft and persistence. The framework also parses SSH configurations, known hosts, and bash history files to identify additional targets and spray harvested credentials across accessible systems to propagate the infection further.

#4

For internet-wide expansion, PCPJack leverages Common Crawl parquet datasets to generate large lists of internet-facing targets. Each infected host is assigned a specific scanning range, enabling decentralized reconnaissance without relying on a central controller. The malware attempts to exploit multiple known vulnerabilities, including CVE-2025-29927 in Next.js for middleware authorization bypass, CVE-2025-55182 in React2Shell for deserialization-based remote code execution, CVE-2026-1357 in WPVivid for unauthenticated file uploads, CVE-2025-9501 in W3 Total Cache for PHP injection, and CVE-2025-48703 in Control Web Panel (CWP) for shell injection. Command-and-control activity is managed through Telegram channels, where infected systems upload stolen data and retrieve instructions through pinned messages. Researchers also uncovered an additional toolkit hosted on the same staging infrastructure, featuring a large shell script named check.sh that deploys Sliver C2 beacons with garble-based obfuscation, steals credentials from services such as Anthropic, OpenAI, Discord, and HashiCorp Vault, and exfiltrates the collected data to a typosquatted CloudFront domain over ports 443 and 8443.

Recommendations



Patch Next.js to Versions 12.3.5, 13.5.9, 14.2.25, or 15.2.3: Immediately upgrade all self-hosted Next.js deployments to the fixed versions that address CVE-2025-29927. If patching is not immediately feasible, strip the x-middleware-subrequest header from all incoming external requests at the load balancer or reverse proxy layer to prevent middleware authorization bypass.



Update React Server Components to Version 19.0.1 or Later: Apply the vendor patch for CVE-2025-55182 (React2Shell) across all deployments using react-server-dom-parcel, react-server-dom-turbopack, or react-server-dom-webpack packages. This vulnerability enables unauthenticated remote code execution and is confirmed to be actively exploited in ransomware campaigns.



Update WordPress Plugins WPVivid Backup and W3 Total Cache: Upgrade WPVivid Backup & Migration to a version above 0.9.123 to remediate CVE-2026-1357, and upgrade W3 Total Cache to version 2.8.13 or later to address CVE-2025-9501. Both vulnerabilities allow unauthenticated remote code execution through distinct attack vectors.



Upgrade CentOS Web Panel to Version 0.9.8.1205 or Later: Apply the patch for CVE-2025-48703 to eliminate the shell injection vulnerability in the filemanager changePerm function. If CWP cannot be immediately patched, restrict network access to the management interface.



Enforce IMDSv2 Across All AWS Services: Disable IMDSv1 and strictly enforce IMDSv2 with session tokens across all AWS EC2 instances and container workloads. PCPJack actively queries IMDS endpoints to steal cloud credentials, and IMDSv2 enforcement prevents this credential harvesting technique.



Restrict Docker and Kubernetes Management API Exposure: Ensure Docker daemon sockets (ports 2375/2376) are not exposed to the network without authentication. Require TLS mutual authentication for remote Docker API access. Apply restrictive RBAC policies to Kubernetes service accounts, limiting access to Secrets and ConfigMaps following the principle of least privilege.



Implement Network Segmentation and East-West Traffic Monitoring: Segment cloud workloads to limit lateral movement between containerized services, databases, and application servers. Deploy network detection rules for scanning activity on ports 2375, 2376, 6379, 8265, and 27017, which PCPJack uses for internal propagation.



Potential MITRE ATT&CK TTPs

Tactic	Technique	Sub-technique
Initial Access	<u>T1190</u> : Exploit Public-Facing Application	
Execution	<u>T1059</u> : Command and Scripting Interpreter	<u>T1059.004</u> : Unix Shell
		<u>T1059.006</u> : Python
Persistence	<u>T1053</u> : Scheduled Task/Job	<u>T1053.003</u> : Cron
	<u>T1543</u> : Create or Modify System Process	<u>T1543.002</u> : Systemd Service
Defense Evasion	<u>T1027</u> : Obfuscated Files or Information	
	<u>T1036</u> : Masquerading	<u>T1036.005</u> : Match Legitimate Name or Location
	<u>T1070</u> : Indicator Removal	<u>T1070.004</u> : File Deletion



Tactic	Technique	Sub-technique
Credential Access	T1552 : Unsecured Credentials	T1552.001 : Credentials In Files
	T1552 : Unsecured Credentials	T1552.005 : Cloud Instance Metadata API
	T1552 : Unsecured Credentials	T1552.007 : Container API
Discovery	T1046 : Network Service Discovery	
	T1613 : Container and Resource Discovery	
Lateral Movement	T1021 : Remote Services	T1021.004 : SSH
	T1610 : Deploy Container	
Collection	T1119 : Automated Collection	
Exfiltration	T1567 : Exfiltration Over Web Service	
Command and Control	T1102 : Web Service	T1102.002 : Bidirectional Communication
	T1071 : Application Layer Protocol	T1071.001 : Web Protocols
Resource Development	T1583 : Acquire Infrastructure	T1583.006 : Web Services

✂ Indicators of Compromise (IOCs)

TYPE	VALUE
Domains	cdn[.]cloudfront-js[.]com, lastpass-login-help[.]com, spm-cdn-assets-dist-2026[.]s3[.]us-east-2[.]amazonaws[.]com
IPv4	38[.]242[.]204[.]245, 38[.]242[.]237[.]196, 38[.]242[.]245[.]147, 83[.]171[.]249[.]231, 161[.]97[.]129[.]25, 161[.]97[.]135[.]154, 161[.]97[.]163[.]87, 161[.]97[.]186[.]175, 161[.]97[.]187[.]42, 193[.]187[.]129[.]143, 213[.]136[.]80[.]73
SHA1	005587975a483876c1fa26b64b418931019be38f, 01cebc48016395e284ac76afc1816f143ee3e7b6, 0b86434ca5145636d745222f7e49c903ce6ef538, 2cd2c5268e41cdece1b0506bcda3b9eba2998119, 2fab324eb0d927846c8744dc0e217beea65138e0, 339cbf61c80f757085c5afb7304d69f323bdf87a, 6060da100b5cd587131a1c11a20d6e0108604744, 848ef1f638807826586802428a7ebafdc710915c, 9c7ab48c9fdbbeecdad8433529bdab38584f0e25, a20a9924d92c2b06d82b79c0fe87451c650cabec, c2dd8051d89c4efa71bd67d2df7d9b4bc3e67810, fed52a4bbac7b5b6ae4f76cab3eadd67e79227e3
File Path	/var/lib/.spm/ /etc/systemd/system/spm-worker.service, /tmp/.origin
File Name	harvest.jsonl



Patch Links

<https://github.com/vercel/next.js/releases>

<https://github.com/facebook/react/security/advisories/GHSA-fv66-9v8q-g76r>

<https://wordpress.org/plugins/wpvivid-backuprestore/>

<https://wordpress.org/plugins/w3-total-cache/>

<http://centos-webpanel.com/>



References

<https://www.sentinelone.com/labs/cloud-worm-evicts-teamcp-and-steals-credentials-at-scale/>

<https://hivepro.com/threat-advisory/nextjs-under-siege-as-cve-2025-29927-opens-the-floodgates-for-attackers/>

<https://hivepro.com/threat-advisory/react2shell-flaw-in-react-server-components-under-active-attack/>

<https://hivepro.com/threat-advisory/teamcp-automated-supply-chain-from-trivy-to-litellm-in-a-multi-ecosystem-breach/>



What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a Demo of HivePro.

REPORT GENERATED ON

May 13, 2026 • 7:30 AM

© 2026 All Rights are Reserved by Hive Pro



More at www.hivepro.com